LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eleminiz?

   Önce emniyet: makineyi güvenli durumda tut (bıçağı durdur, e-stop, enerjiyi kes/servis moduna al, kimse bıçak bölgesine yaklaşmasın). Ararım: bakım/emniyet sorumlusu, BT/OT güvenlik, üretici servisi. İlk üç eylem: (1) durdur + güvenli duruma al, (2) uzak erişimi ve servis hesabını izole et, (3) ekran/log görüntüsünü al; resetleme.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Doğrulama: kafes kilidi, e-stop, pedal ve kavrama/fren fonksiyon testi (boş bıçak bölgesi); NC/PLC konfigürasyonu bilinen iyi yedekle karşılaştırılır. Korunan kanıt: loglar, konfigürasyon kopyası, VPN/erişim kayıtları, saat/IP bilgisi (RESET YOK). Kapatılan: ele geçirilen servis hesabı, varsayılan/paylaşılan parolalar, uzak erişim.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Hazır olmalı: fark edilme saati, etkilenen ürün/sürüm (VMGS 2504 + varsa NC opsiyonu), kısa olay tanımı (03:00 yetkisiz servis erişimi), istismar şüphesi, emniyet etkisi (koruma parametreleri doğrulandı mı), alınan ilk önlemler, etkilenen müşteri/ülke bilgisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (nasıl girildi: uzak modül/zayıf hesap), etki (hangi parametre değişti, emniyet fonksiyonu etkilendi mi), önlem (hesap kapatma, VPN+MFA, yama). Kim: üretici ürün güvenliği ekibi bildirimi yapar; vardiya sorumlusu bilgi ve log sağlar; bakım fonksiyon testini yapar; yönetim onaylar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Oturum/VPN/erişim logları, hesap giriş kayıtları, konfigürasyon öncesi-sonrası kopyaları, emniyet fonksiyonu test sonuçları, olay zaman çizelgesi, düzeltici eylemler ve yama/doğrulama kayıtları; hepsi zaman damgalı ve değiştirilmeden saklanmış olmalı.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.